

SIFT Defender Agent

Autonomous Read-Only DFIR for “Find Evil”

Direct Agent Extension (Claude Code) on the SANS SIFT Workstation · read-only by architecture

OVERVIEW

What It Does

Digital forensics investigations often require analysts to manually execute dozens of commands, inspect thousands of artifacts, correlate evidence across filesystems, email stores, timelines, browser data, and attacker tools, and then produce a defensible report. This process is slow, repetitive, and highly dependent on analyst experience.

Our project, **SIFT Defender Agent**, transforms that workflow into an autonomous DFIR analyst running on the SANS SIFT Workstation.

The agent accepts a forensic disk image (E01, raw image, etc.) and automatically:

- Detects partitions and filesystems
- Extracts forensic metadata
- Generates timelines
- Identifies attacker tooling
- Detects credential-theft activity
- Detects anti-forensics behavior
- Identifies data-exfiltration attempts
- Parses email evidence
- Correlates artifacts across multiple evidence sources
- Self-classifies the investigation type
- Produces a severity-ranked forensic report
- Preserves evidence integrity through a read-only architecture

Unlike traditional forensic automation scripts that follow a fixed path, our agent dynamically determines whether the case is an Intrusion, Insider Threat, Data Exfiltration, Social Engineering, or Malware Investigation — and changes its reasoning workflow accordingly.

ARCHITECTURE

How We Built It

Our solution consists of three primary components.

1. Autonomous DFIR Agent

The core reasoning engine runs through Claude Code. We created a highly constrained DFIR operating procedure in **CLAUDE.md** that acts as the agent’s forensic playbook. The agent is instructed to:

- Collect evidence only once
- Avoid redundant tool executions
- Remain evidence-driven
- Avoid hallucinations
- Cite artifacts for every finding
- Distinguish evidence confidence levels

The prompt effectively teaches the model to behave like a senior incident responder, and explicitly forbids it from making any claim that is not supported by evidence.

2. Read-Only Evidence Collection Layer

The second component is **collect.sh**, a forensic acquisition layer that automatically gathers a compact evidence bundle the LLM can analyze efficiently — without repeatedly touching the original image.

Stage	What it collects
Filesystem metadata	mmls, fsstat
File enumeration	fls
Timeline creation	mactime
Prefetch analysis	execution evidence
Recycle Bin analysis	deleted attacker tools
Email extraction	PST and MBOX stores
Attachment discovery	outbound documents, exfiltration candidates
Browser / webmail artifacts	Gmail, Yahoo, Outlook

3. Investigation-Type Detection

One of the most important design choices was letting the evidence determine the investigation workflow. Most DFIR automation assumes every case is an intrusion; real investigations are more complex. Our agent first determines the track, then asks track-specific questions.

Track	Indicators	Questions answered
Intrusion	Cain & Abel, Pwdump, Netcat, Nmap, Brutus, NetBus	What attacker tools exist? Which executed? Was anti-forensics used?
Exfiltration	Sensitive spreadsheets, payroll data, SSNs, outbound email attachments	What sensitive data left? Who requested it? Who received it? Was the request legitimate?
Malware	Suspicious executables, dropped payloads	What is the malware? What capabilities does it have?

This adaptive workflow allows a single agent to investigate multiple case categories.

VALIDATION

Example Results

Case 1 — CReDS: “Mr. Evil”

The agent identified a full attacker toolkit and confirmed execution from prefetch evidence.

Category	Findings
Confirmed execution	Cain & Abel (prefetch evidence)
Credential theft	pwdump, samdump
Network reconnaissance	nmap, nbtscan, enum
Anti-forensics	ELSAVE (event-log wiping)
Privilege escalation	GetAdmin, Sechole
Remote access	NetBus, VNC
Deleted recon tools	NetStumbler, Ethereal, WinPcap (recovered from Recycle Bin)

Classification: Attacker Staging System

Case 2 — Digital Corpora: “Jean”

From a completely different disk, the same agent identified an entirely different scenario — no attacker toolkit existed.

Evidence	Detail
Sensitive spreadsheet	Employee names, salaries, and SSNs
Social-engineering request	Appeared to come from alison@m57.biz; later messages originated from tuckgorge@gmail.com
Outbound disclosure	Jean sent m57biz.xls containing employee information

Classification: Social Engineering → Data Exfiltration (not malware or intrusion)

This demonstrated the adaptive reasoning capability of the system.

WHY IT COUNTS AS AUTONOMOUS
Autonomous Execution Features

Dynamic Planning

The agent chooses investigation paths based on evidence, not pre-programmed case categories.

Evidence-Grounded Reasoning

Every conclusion must map to a specific artifact, inode, and source file, which significantly reduces hallucinations.

Self-Correction

The agent continuously evaluates findings and labels them by confidence — mirroring how experienced analysts express certainty:

CONFIRMED · LIKELY · UNVERIFIED

Tool Minimization

Instead of repeatedly querying the image, the agent collects once, analyzes the bundle, and executes targeted retrieval only when needed — improving speed and reproducibility.